BASTIONADO DE UN EQUIPO INFORMATICO

Carlos Munaiz Cossio

CEU Master Ciberseguridad

Contenido

Instalación de Herramientas y sistemas operativos necesarios/usados..... 1
Purple Kali Linux 2024.1 1
Nmap 1
Tcdump/tshark 1
Wireshark 2
SNMP 2
FwBuilder 3
Alma Linux 10 4
OpenSSH 4
RSSH 5
ACL POSIX 6
Rsyslog 6
Logwatch 7
GoAccess 7
Bacula 8
Descubrimiento inicial 9
A. Desde Kali utiliza nmap para realizar un escaneo. 9
Comprueba la lista de puerto abiertos localmente en Alma. 11
Lista los puertos. 11
¿En qué capa del modelo OSI actúa principalmente? 11
Captura el tráfico con Kali. 12
Utiliza tcpdump 12
En paralelo utiliza Wireshark o Tshark. 12
¿En qué capa del modelo OSI actúa principalmente? 13
OpenSSH 13
Evidencia del estado del servicio. 13
Evidencia de conexión por ssh 14
¿En qué capa del modelo OSI está actuando kali? 14
Configurar chroot SFTP en OpenSSH 14
Creamos usuario y su directorio personal 14
Evidencia del archivo de configuración modificado. 14
Comando/comandos utilizados para la creación/asignación de permisos del directorio y justificación de la sentencia/s. 15
Verificamos que el usuario esta correcto 15
Crea el directorio principal para el usuario backupuser. 15
Asigna propiedad root:root al directorio base. 16

Reiniciamos sshd 17
Verificamos la defensa del sftp: 17
Comprobamos que no pueda salir o realizar acciones que hemos restringido. 18
1. Intentar salir del chroot 18
2. Intentar escribir en el directorio raíz 18
3. Intentar crear un directorio en raíz 18
4. Intentar ejecutar comandos de Shell 18
5. Intentar acceder por SSH normal 18
6. Intentar túnel (Lo bloqueamos con AllowTcpFowarding). 19
¿En qué capa del modelo OSI está actuando Alma? 19
Listas de control de acceso y firewall (ACL) 19
Crear carpeta y asignar permisos 19
Crear directorio 19
Cambiar propietario y grupo 19
Asignar permisos 20
Evidencia 20
Explicación de getfacl / setfacl 20
getfacl 20
setfacl 20
Comprobar ACL actuales 21
Dar permisos a backupuser 21
Comprobar 21
Herencia de ACL 22
Aplicar ACL recursivamente 22
Establecer ACL por defecto 22
Comprobar ACL finales 23
Evidencia final 23
Iptables en AlmaLinux 24
Comprobar iptables-services 24
Comprobar si está instalado 24
Instalar si no está 24
Detener firewall de Alma 24
Limpiar reglas de iptables 25
Crear regla SSH 25
Configurar iptables modo restrictivo 25
Permitir conexiones establecidas 26
Política restrictiva 26
Guardar reglas 26

Activar persistencia 26
Verificar iptables 27
Mostrar reglas 27
Guardar reglas en archivo 27
Probar conexión desde Kali 27
Pregunta del ejercicio 28
¿En qué capa OSI actúa Alma? 28
¿Qué otras medidas nos ofrece iptables para securizar las conexiones? 28
Limitar intentos SSH (anti brute force) 28
Bloquear una IP específica 28
Permitir acceso solo una red 28
Mitigación de ICMP 28
Comprobar política INPUT DROP 28
Método 1 – Bloquear ICMP con iptables 29
Guardar reglas 30
Método 2 – Bloqueo a nivel de Kernel 30
Hacerlo persistente 30
Evidencia 31
Verificar desde Kali 31
¿Qué es ICMP? 32
¿Por qué es buena idea bloquearlo? 32
Diferencias entre método 1 y método 2 32
Método 1 – iptables 32
Método 2 – kernel 32

Laboratorio 6: Bastionado de un equipo informático.

Instalación de Herramientas y sistemas operativos necesarios/usados

Purple Kali Linux 2024.1

Nmap

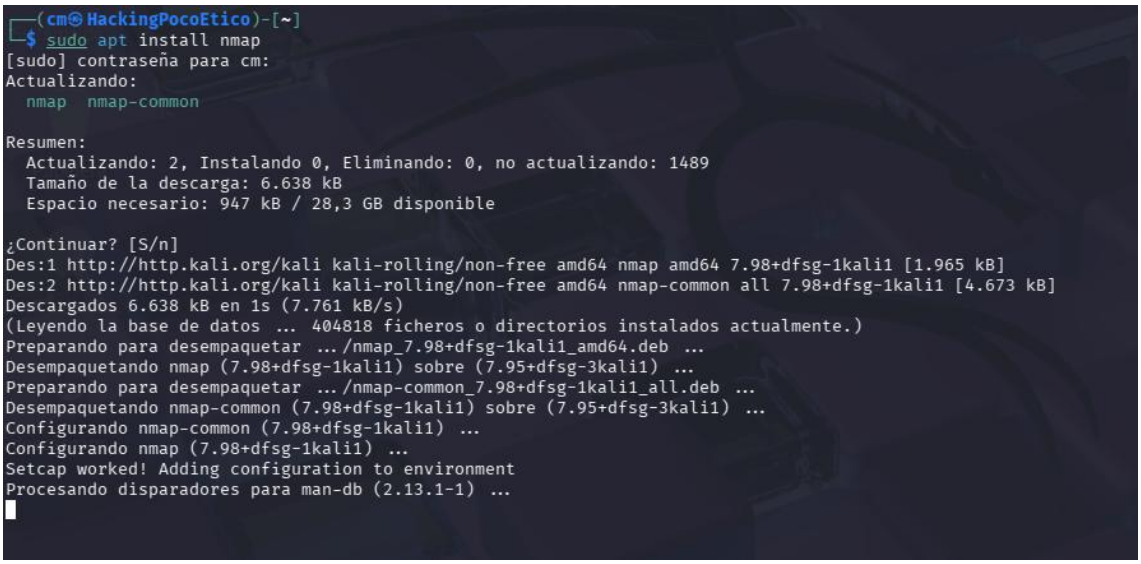
1. Descripción.

Herramienta de escaneo de red utilizada para descubrimiento de hosts, detección de puertos abiertos, identificación de servicios y versiones, y detección de sistema operativo.

2. Instalación (si fuese necesaria)

sudo apt install nmap

3. Evidencia.



```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ sudo apt install nmap
[sudo] contraseña para cm:
Actualizando:
  nmap  nmap-common

Resumen:
  Actualizando: 2, Instalando 0, Eliminando: 0, no actualizando: 1489
  Tamaño de la descarga: 6.638 kB
  Espacio necesario: 947 kB / 28,3 GB disponible

¿Continuar? [S/n]
Des:1 http://http.kali.org/kali kali-rolling/non-free amd64 nmap amd64 7.98+dfsg-1kali1 [1.965 kB]
Des:2 http://http.kali.org/kali kali-rolling/non-free amd64 nmap-common all 7.98+dfsg-1kali1 [4.673 kB]
Descargados 6.638 kB en 1s (7.761 kB/s)
(Leyendo la base de datos ... 404818 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../nmap_7.98+dfsg-1kali1_amd64.deb ...
Desempaquetando nmap (7.98+dfsg-1kali1) sobre (7.95+dfsg-3kali1) ...
Preparando para desempaquetar .../nmap-common_7.98+dfsg-1kali1_all.deb ...
Desempaquetando nmap-common (7.98+dfsg-1kali1) sobre (7.95+dfsg-3kali1) ...
Configurando nmap-common (7.98+dfsg-1kali1) ...
Configurando nmap (7.98+dfsg-1kali1) ...
Setcap worked! Adding configuration to environment
Procesando disparadores para man-db (2.13.1-1) ...
```

Tcdump/tshark

1. Descripción.

Herramientas de captura y análisis de tráfico de red en línea de comandos. Permiten inspeccionar paquetes en tiempo real.

2. Instalación (si fuese necesaria)

sudo apt install tcpdump tshark

3. **Evidencia.**

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ sudo apt install tcpdump tshark
tcpdump ya está en su versión más reciente (4.99.5-2).
fijado tcpdump como instalado manualmente.
Actualizando:
  libwireshark-data  libwireshark19  libwiretap16  libwsutil17  tshark  wireshark  wireshark-common

Resumen:
  Actualizando: 7, Instalando 0, Eliminando: 0, no actualizando: 1482
  Tamaño de la descarga: 28,2 MB
 Espacio liberado: 375 kB

¿Continuar? [S/n] s
Des:1 http://kali.download/kali kali-rolling/main amd64 libwsutil17 amd64 4.6.3-1 [160 kB]
Des:3 http://kali.download/kali kali-rolling/main amd64 libwireshark19 amd64 4.6.3-1 [22,0 MB]
Des:2 http://mirror.es.cdn-perfprod.com/kali kali-rolling/main amd64 libwiretap16 amd64 4.6.3-1 [295 kB]
Des:4 http://kali.download/kali kali-rolling/main amd64 tshark amd64 4.6.3-1 [187 kB]
Des:5 http://kali.download/kali kali-rolling/main amd64 wireshark amd64 4.6.3-1 [4.434 kB]
Des:6 http://kali.download/kali kali-rolling/main amd64 wireshark-common amd64 4.6.3-1 [650 kB]
Des:7 http://kali.download/kali kali-rolling/main amd64 libwireshark-data all 4.6.3-1 [453 kB]
Descargados 28,2 MB en 1s (33,1 MB/s)
Preconfigurando paquetes ...
(Leyendo la base de datos ... 404821 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../0-libwsutil17_4.6.3-1_amd64.deb ...
Desempaquetando libwsutil17:amd64 (4.6.3-1) sobre (4.6.0-1) ...
Preparando para desempaquetar .../1-libwiretap16_4.6.3-1_amd64.deb ...
Desempaquetando libwiretap16:amd64 (4.6.3-1) sobre (4.6.0-1) ...
Preparando para desempaquetar .../2-libwireshark19_4.6.3-1_amd64.deb ...
Desempaquetando libwireshark19:amd64 (4.6.3-1) sobre (4.6.0-1) ...
Preparando para desempaquetar .../3-tshark_4.6.3-1_amd64.deb ...
```

Wireshark

1. **Descripción.**

Wireshark es un analizador de protocolos de red que permite capturar y examinar paquetes en tiempo real. Se utiliza para diagnóstico de problemas de red, análisis de seguridad, detección de tráfico sospechoso y estudio del comportamiento de protocolos como TCP, HTTP, DNS, ARP, entre otros.

Permite aplicar filtros de visualización, reconstruir sesiones y analizar el contenido detallado de cada paquete capturado.

2. **Instalación (si fuese necesaria)**

sudo apt install wireshark

3. **Evidencia.**

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ sudo apt install wireshark
wireshark ya está en su versión más reciente (4.6.3-1).
fijado wireshark como instalado manualmente.
Resumen:
  Actualizando: 0, Instalando 0, Eliminando: 0, no actualizando: 1482

┌──(cm㉿HackingPocoEtico)-[~]
└─$
```

SNMP

1. **Descripción.**

SNMP (Simple Network Management Protocol) es un protocolo de gestión de red utilizado para monitorizar y administrar dispositivos como servidores, routers, switches e impresoras.

Funciona mediante:

- **Manager** (cliente que consulta)

- **Agent** (servicio que responde en el dispositivo)
- **MIB** (Base de Información de Gestión)
- **OID** (Identificadores de objetos)

Permite obtener información como:

- Uso de CPU
- Interfaces de red
- Estado del sistema
- Tiempo de actividad (uptime)

Las versiones más comunes son:

- SNMPv1 (básica)
- SNMPv2c (usa comunidad, ej. “public”)
- SNMPv3 (segura, con autenticación y cifrado)

2. Instalación (si fuese necesaria)

sudo apt install snmp snmp-mibs-downloader

3. Evidencia.

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ sudo apt install snmp snmp-mibs-downloader
Instalando:
  snmp  snmp-mibs-downloader

Instalando dependencias:
  libsnmp45  smistrip

Resumen:
  Actualizando: 0, Instalando 4, Eliminando: 0, no actualizando: 1482
  Tamaño de la descarga: 8.696 kB
  Espacio necesario: 12,4 MB / 28,3 GB disponible

¿Continuar? [S/n] S
Des:1 http://http.kali.org/kali kali-rolling/main amd64 libsnmp45 amd64 5.9.5.2+dfsg-2.1 [2.635 kB]
Des:2 http://http.kali.org/kali kali-rolling/main amd64 smistrip all 0.4.8+dfsg2-18 [26,0 kB]
Des:3 http://http.kali.org/kali kali-rolling/main amd64 snmp amd64 5.9.5.2+dfsg-2.1 [179 kB]
Des:4 http://kali.download/kali kali-rolling/non-free amd64 snmp-mibs-downloader all 1.8 [5.856 kB]
Descargados 8.696 kB en 1s (15,4 MB/s)
Seleccionando el paquete libsnmp45:amd64 previamente no seleccionado.
```

FwBuilder

1. Descripción.

FwBuilder (Firewall Builder) es una herramienta gráfica utilizada para diseñar, configurar y gestionar reglas de firewall de forma estructurada.

Permite crear políticas de seguridad visualmente y luego generar automáticamente la configuración para distintos motores de firewall como:

- iptables (Linux)
- pf (BSD)
- Cisco ACL

Facilita:

- Creación de reglas de filtrado
- Definición de objetos de red (hosts, redes, servicios)
- Configuración de NAT
- Gestión centralizada de políticas

Es especialmente útil en entornos académicos para modelar reglas sin escribir manualmente comandos complejos.

2. Instalación (si fuese necesaria)

sudo apt install fwbuilder

3. Evidencia.

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ sudo apt install fwbuilder
Actualizando:
  fwbuilder

Resumen:
  Actualizando: 1, Instalando 0, Eliminando: 0, no actualizando: 1481
  Tamaño de la descarga: 7.882 kB
  Espacio necesario: 479 kB / 28,2 GB disponible

Des:1 http://http.kali.org/kali kali-rolling/main amd64 fwbuilder amd64 5.3.7-8+b2 [7.882 kB]
Descargados 7.882 kB en 0s (17,0 MB/s)
(Leyendo la base de datos ... 405258 ficheros o directorios instalados actualmente.)
Preparando para desempaquetar .../fwbuilder_5.3.7-8+b2_amd64.deb ...
Desempaquetando fwbuilder (5.3.7-8+b2) sobre (5.3.7-8+b1) ...
Configurando fwbuilder (5.3.7-8+b2) ...
Procesando disparadores para shared-mime-info (2.4-5+b3) ...
Procesando disparadores para menu (2.1.51) ...
Procesando disparadores para kali-menu (2025.4.3) ...
Procesando disparadores para desktop-file-utils (0.28-1) ...
Procesando disparadores para man-db (2.13.1-1) ...
```

Alma Linux 10

OpenSSH

1. Descripción.

OpenSSH es una implementación libre del protocolo SSH (Secure Shell) que permite el acceso remoto seguro a sistemas mediante cifrado.

Se utiliza para:

Administración remota segura.

Transferencia de archivos mediante SCP o SFTP.

Ejecución remota de comandos.

Túneles cifrados.

Funciona bajo modelo cliente-servidor, donde el servicio sshd escucha normalmente en el puerto 22/TCP.

2. Instalación (si fuese necesaria)

sudo dnf install openssh-server -y

3. Evidencia.

```
root@localhost:/home/cmalma# sudo dnf install openssh-server -y
Última comprobación de caducidad de metadatos hecha hace 0:22:14, el lun 02 mar 2026 18:19:21.
El paquete openssh-server-9.9p1-12.el10_1.alma.1.x86_64 ya está instalado.
Dependencias resueltas.
Nada por hacer.
¡Listo!
root@localhost:/home/cmalma#
```

RSSH

1. Descripción.

rssh (Restricted Shell) es una shell restringida diseñada para limitar las acciones que puede realizar un usuario en el sistema.

Se utiliza principalmente para permitir únicamente:

- SFTP
- SCP
- Rsync

Sin permitir acceso a una shell interactiva tradicional (bash).

Es útil en entornos donde se necesita permitir transferencia de archivos, pero sin otorgar control total del sistema.

2. Instalación (si fuese necesaria)

AlmaLinux:

sudo dnf install epel-release -y

sudo dnf install rssh -y

Archivcd /o de configuración principal:

/etc/rssh.conf

Ejemplo básico de configuración habilitando solo scp y sftp:

allowscp
allowsftp

Asignar rssh como shell de un usuario:

sudo useradd usuario_restringido -s /usr/bin/rssh

O modificar un usuario existente:

sudo usermod -s /usr/bin/rssh usuario_restringido

ATENCION. EN LA VERSION NUEVA DE ALMA NO EXISTE SOLO EN ALMA 8

ACL POSIX

1. Descripción.

Las ACL POSIX (Access Control Lists) permiten definir permisos de acceso más granulares que el modelo tradicional de Linux (usuario – grupo – otros).

Mientras que el modelo clásico solo permite permisos básicos (rwx), las ACL permiten:

- Asignar permisos específicos a múltiples usuarios.
- Asignar permisos específicos a múltiples grupos.
- Definir ACL por defecto en directorios.
- Gestionar accesos más complejos en entornos multiusuario.

Se utilizan principalmente en servidores donde varios usuarios necesitan distintos niveles de acceso a los mismos recursos.

2. Instalación (si fuese necesaria)

sudo dnf install acl -y

3. Evidencia.

```
cmalma@localhost:/$ sudo dnf install acl -y
Última comprobación de caducidad de metadatos hecha hace 0:03:49, el lun 02 mar 2026 18:52:12.
El paquete acl-2.3.2-4.el10.x86_64 ya está instalado.
Dependencias resueltas.
Nada por hacer.
¡Listo!
```

Rsyslog

1. Descripción.

RSyslog es un sistema de registro de eventos (logging) utilizado en sistemas Linux para recopilar, procesar y almacenar mensajes generados por el sistema operativo, servicios y aplicaciones.

Permite:

- Centralizar logs.
- Filtrar mensajes por nivel de severidad.
- Redirigir logs a archivos específicos.
- Enviar logs a servidores remotos.
- Integrarse con sistemas SIEM.

Trabaja con niveles de prioridad como:

- info
- warning
- err
- crit

- debug

Es una herramienta fundamental para auditoría, monitorización y análisis forense.

2. Instalación (si fuese necesaria)

```
sudo dnf install rsyslog -y
```

3. Evidencia.

```
cmalma@localhost:/$ sudo dnf install rsyslog -y
Última comprobación de caducidad de metadatos hecha hace 0:06:06, el lun 02 mar 2026 18:52:12.
El paquete rsyslog-8.2506.0-2.el10.x86_64 ya está instalado.
Dependencias resueltas.
Nada por hacer.
¡Listo!
cmalma@localhost:/$
```

Logwatch

1. Descripción.

Logwatch es una herramienta de análisis y generación de informes basada en los logs del sistema.

Su función principal es:

- Analizar automáticamente los archivos de log.
- Resumir eventos relevantes.
- Presentar reportes estructurados por categorías.
- Detectar posibles incidentes o anomalías.

Es especialmente útil para administradores de sistemas, ya que transforma grandes volúmenes de logs en informes comprensibles.

Puede generar informes diarios, semanales o personalizados y enviarlos por correo electrónico.

2. Instalación (si fuese necesaria)

sudo dnf install logwatch -y

3. Evidencia.

```
cmalma@localhost:/$ sudo dnf install logwatch -y
Última comprobación de caducidad de metadatos hecha hace 0:07:50, el lun 02 mar 2026 18:52:12.
Dependencias resueltas.
================================================================================================================
 Paquete                          Arquitectura       Versión                        Repositorio          Tam.
================================================================================================================
Instalando:
 logwatch                         noarch             7.11-4.el10                    appstream            428 k
Instalando dependencias:
 perl-Clone                       x86_64             0.46-10.el10                   appstream             22 k
 perl-Compress-Raw-Bzip2          x86_64             2.212-512.el10                 appstream             35 k
 perl-Compress-Raw-Zlib           x86_64             2.212-512.el10                 appstream             64 k
 perl-Date-Manip                  noarch             6.94-5.el10                    appstream            1.2 M
 perl-Encode-Locale               noarch             1.05-31.el10                   appstream             18 k
 perl-HTML-Parser                 x86_64             3.82-3.el10                    appstream            126 k
 perl-HTML-Tagset                 noarch             3.20-59.el10                   appstream             18 k
 perl-HTTP-Date                   noarch             6.06-6.el10                    appstream             24 k
 perl-HTTP-Message                noarch             6.45-5.el10                    appstream            102 k
 perl-I18N-Langinfo               x86_64             0.24-512.2.el10_0              appstream             25 k
```

GoAccess

1. Descripción.

GoAccess es una herramienta de análisis de logs web en tiempo real.

Permite analizar archivos de registro generados por servidores web como:

- Apache
- Nginx
- Lighttpd

Su función principal es:

- Analizar tráfico web.
- Mostrar estadísticas de visitantes.
- Identificar IPs, URLs más visitadas y códigos de estado.
- Detectar posibles comportamientos sospechosos.

Puede funcionar en modo terminal o generar informes HTML interactivos.

Es muy útil para auditoría de accesos y monitorización de actividad web.

2. Instalación (si fuese necesaria)

```
sudo dnf install goaccess -y
```

3. Evidencia.

```
cmalma@localhost:/$ sudo dnf install goaccess -y
Última comprobación de caducidad de metadatos hecha hace 0:09:14, el lun 02 mar 2026 18:52:12.
Dependencias resueltas.
================================================================================================================
 Paquete                    Arquitectura            Versión                          Repositorio            Tam.
================================================================================================================
Instalando:
 goaccess                   x86_64                  1.9.4-1.el10_1                   epel                   466 k

Resumen de la transacción
================================================================================================================
Instalar  1 Paquete

Tamaño total de la descarga: 466 k
Tamaño instalado: 1.5 M
Descargando paquetes:
goaccess-1.9.4-1.el10_1.x86_64.rpm                                          7.9 MB/s | 466 kB     00:00
----------------------------------------------------------------------------------------------------------------
Total                                                                       584 kB/s | 466 kB     00:00
Extra Packages for Enterprise Linux 10 - x86_64                             1.6 MB/s | 1.6 kB     00:00
Importando llave GPG 0xE37ED158:
 ID usuario: "Fedora (epel10) <epel@fedoraproject.org>"
 Huella    : 7D8D 15CB FC4E 6268 8591 FB26 33D9 8517 E37E D158
 Desde     : /etc/pki/rpm-gpg/RPM-GPG-KEY-EPEL-10
```

Bacula

1. Descripción.

Bacula es una solución de copias de seguridad (backup) de tipo cliente-servidor orientada a entornos empresariales.

Permite:

- Realizar copias completas, incrementales y diferenciales.

- Programar tareas automáticas.
- Restaurar archivos específicos o sistemas completos.
- Gestionar múltiples clientes desde un servidor central.

Su arquitectura se compone de:

- **Director (bacula-dir)** → Controla los trabajos de backup.
- **Storage Daemon (bacula-sd)** → Gestiona el almacenamiento.
- **File Daemon (bacula-fd)** → Cliente instalado en los equipos a respaldar.

Es una herramienta avanzada utilizada en infraestructuras críticas para garantizar disponibilidad y recuperación ante desastres.

2. Instalación (si fuese necesaria)

Activamos el crb:

sudo dnf config-manager --set-enabled crb

sudo dnf install dnf-plugins-core -y

Instalamos epel

sudo dnf install epel-release -y

sudo dnf update -y

3. Evidencia.

El paquete Bacula no se encuentra disponible en los repositorios habilitados para la versión actual de AlmaLinux. Para cumplir el objetivo de copias de seguridad se requiere un repositorio externo del fabricante/proyecto o el uso de una versión del sistema con el paquete disponible (p. ej., AlmaLinux 8), o bien una alternativa soportada.

Descubrimiento inicial

A. Desde Kali utiliza nmap para realizar un escaneo.

Usamos este comando para escanear La Maquina Alma:

nmap -sS -sV -Pn "IP_ALMA"

-sS: Escanea TCP SYN, es decir envia un paquete syn y si responde ack abierto si responde rst cerrado

-sV: Identifica puertos abiertos y dice que servicio corren (Apache,SSH,FTP,etc…)

-Pn: Hace un host Discovery y si no hay ping lo escanea igual (es útil por si hay un firewall que bloquea ICMP o si el host no responde a ping pero tiene servicios abiertos)

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ nmap -sS -sV -Pn -vvv 192.168.1.144
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-02 19:25 +0100
NSE: Loaded 48 scripts for scanning.
Initiating ARP Ping Scan at 19:25
Scanning 192.168.1.144 [1 port]
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
ARP Ping Scan Timing: About 100.00% done; ETC: 19:25 (0:00:00 remaining)
Completed ARP Ping Scan at 19:25, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 19:25
Completed Parallel DNS resolution of 1 host. at 19:25, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 3, OK: 1, NX: 0, DR: 0, SF: 0, TR: 1, CN: 0]
```

```
PORT     STATE SERVICE     REASON         VERSION
22/tcp   open  ssh         syn-ack ttl 64 OpenSSH 9.9 (protocol 2.0)
9090/tcp open  zeus-admin? syn-ack ttl 64
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.c
gi?new-service :
SF-Port9090-TCP:V=7.98%I=7%D=3/2%Time=69A5D618%P=x86_64-pc-linux-gnu%r(Get
SF:Request,31,"HTTP/1\.1\x20400\x20Client\x20Error\r\n\r\nIncorrect\x20req
SF:uest\.\r\n")%r(SqueezeCenter_CLI,31,"HTTP/1\.1\x20400\x20Client\x20Erro
```

```
SF:r\n");
MAC Address: 00:0C:29:78:3E:89 (VMware)
```

Descubrimos puertos.

nmap -p- -vvv 'IP_ALMA'

-p-: Estas diciendo escanea los 65.535 puertos TCP

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ nmap -p- -vvv 192.168.1.144
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-02 19:41 +0100
Initiating ARP Ping Scan at 19:41
Scanning 192.168.1.144 [1 port]
Completed ARP Ping Scan at 19:41, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 19:41
Completed Parallel DNS resolution of 1 host. at 19:41, 0.00s elapsed
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 3, OK: 1, NX: 0, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 19:41
```

```
Host is up, received arp-response (0.00012s latency).
Scanned at 2026-03-02 19:41:37 CET for 152s
Not shown: 65377 filtered tcp ports (no-response), 156 filtered tcp ports (admin-prohibited)
PORT     STATE SERVICE    REASON
22/tcp   open  ssh        syn-ack ttl 64
9090/tcp open  zeus-admin syn-ack ttl 64
MAC Address: 00:0C:29:78:3E:89 (VMware)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 151.55 seconds
           Raw packets sent: 131013 (5.765MB) | Rcvd: 159 (11.348KB)
```

Una Forma más rápida y profesional seria usar este comando (Sobretodo para acelerar el proceso):

nmap -p- -T4 IP_ALMA

nmap -p PUERTOS_ENCONTRADOS -sV -sC IP_ALMA

Primero los descubres todos y después los enumeras bien

También usando:

--min-rate 5000 -> Obliga a nmap a enviar mínimo 5k paquetes por segundo así el lab va muchísimo mas rápido. Pero en laboratorios dado que en un entorno real tienes que tener cuidado porque generas mucho ruido y activas IDS.

Lista los puertos descubiertos.

```
Host is up, received arp-response (0.00012s latency).
Scanned at 2026-03-02 19:41:37 CET for 152s
Not shown: 65377 filtered tcp ports (no-response), 156 filtered tcp ports (admin-prohibited)
PORT     STATE SERVICE    REASON
22/tcp   open  ssh        syn-ack ttl 64
9090/tcp open  zeus-admin syn-ack ttl 64
MAC Address: 00:0C:29:78:3E:89 (VMware)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 151.55 seconds
           Raw packets sent: 131013 (5.765MB) | Rcvd: 159 (11.348KB)
```

El puerto ssh está abierto y el servicio Zeus-admin.

¿En qué capa del modelo OSI actúa principalmente?

Usa la capa 3 (la capa de red (IP)), y la capa 4 (Transporte)

Comprueba la lista de puerto abiertos localmente en Alma.

Lista los puertos.

Ss -tulnp

-t : muestra los sockets TCP

-u: Sockets UDP

-l: los que están Listening (escuchando es decir servidores esperando conexiones o no conexiones ya establecidas)

-n: Numericos, es decir no resuelve nombres (te pone los números 22 no ssh, 80 nohttp, etc…)

-p: Process, muestra que proceso está usando el puerto

```
cmalma@localhost:~$ ss -tulnp
Netid       State       Recv-Q      Send-Q                                  Local Address:Port            Peer Address:Port      Process
udp         UNCONN      0           0                                            0.0.0.0:5353                 0.0.0.0:*
udp         UNCONN      0           0                                          127.0.0.1:323                  0.0.0.0:*
udp         UNCONN      0           0                                              [::]:5353                    [::]:*
udp         UNCONN      0           0                                             [::1]:323                     [::]:*
udp         UNCONN      0           0                  [fe80::20c:29ff:fe78:3e89]%ens160:546                    [::]:*
tcp         LISTEN      0           128                                          0.0.0.0:22                   0.0.0.0:*
tcp         LISTEN      0           4096                                       127.0.0.1:631                  0.0.0.0:*
tcp         LISTEN      0           128                                            [::]:22                    [::]:*
tcp         LISTEN      0           4096                                          [::1]:631                   [::]:*
tcp         LISTEN      0           4096                                              *:9090                     *:*
```

Se ve como están abiertos el 9090 y el 22

¿En qué capa del modelo OSI actúa principalmente?

La capa 4 de transporte dado que estamos viendo sockets TCP t UDp que son puertos del sistema.

Captura el tráfico con Kali.

Utiliza tcpdump

sudo tcpdump -i eth0 host 192.168.1.144

sudo: ejecuta comandos con root

tcpdump: Herramienta para capturar paquetes a tiempo real

-i eth0: “-i” es interface y eth0 es la interfaz la cual quiere capturar el trafico, suele tener varias cada maquina, eth0, ens33, wlan0, lo.

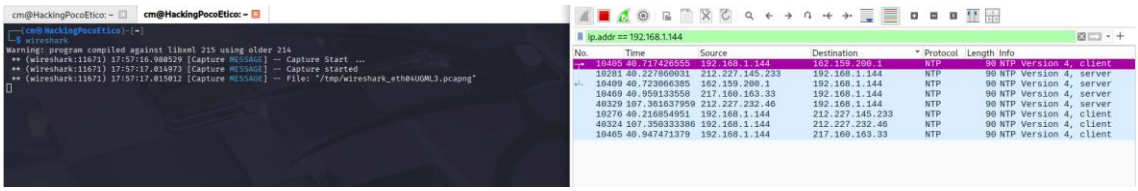
Host: en este caso 192.168.1.144

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ sudo tcpdump -v -i eth0 host 192.168.1.144
tcpdump: listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
17:49:20.482316 IP (tos 0x0, ttl 64, id 30683, offset 0, flags [DF], proto UDP (17), length 76)
    192.168.1.144.57235 > time.cloudflare.com.ntp: NTPv4, Client, length 48
        Leap indicator:  (0), Stratum 0 (unspecified), poll 6 (64s), precision 32
        Root Delay: 0.000000, Root dispersion: 0.000000, Reference-ID: (unspec)
          Reference Timestamp:  0.000000000
          Originator Timestamp: 0.000000000
          Receive Timestamp:    0.000000000
          Transmit Timestamp:   3929799474.548522773 (2024-07-12T18:57:54Z)
            Originator - Receive Timestamp:  0.000000000
            Originator - Transmit Timestamp: 3929799474.548522773 (2024-07-12T18:57:54Z)
17:49:20.488503 IP (tos 0x0, ttl 56, id 41718, offset 0, flags [DF], proto UDP (17), length 76)
    time.cloudflare.com.ntp > 192.168.1.144.57235: NTPv4, Server, length 48
        Leap indicator:  (0), Stratum 3 (secondary reference), poll 6 (64s), precision -25
        Root Delay: 0.036544, Root dispersion: 0.000534, Reference-ID: 0x0a380804
          Reference Timestamp:  3981545313.449678670 (2026-03-03T16:48:33Z)
          Originator Timestamp: 3929799474.548522773 (2024-07-12T18:57:54Z)
          Receive Timestamp:    3981545360.485534258 (2026-03-03T16:49:20Z)
          Transmit Timestamp:   3981545360.486033547 (2026-03-03T16:49:20Z)
            Originator - Receive Timestamp:  +51745885.937011485
            Originator - Transmit Timestamp: +51745885.937510773
17:49:21.746692 IP (tos 0x0, ttl 64, id 14985, offset 0, flags [DF], proto UDP (17), length 76)
    192.168.1.144.45412 > ip212-227-145-233.pbiaas.com.ntp: NTPv4, Client, length 48
        Leap indicator:  (0), Stratum 0 (unspecified), poll 6 (64s), precision 32
        Root Delay: 0.000000, Root dispersion: 0.000000, Reference-ID: (unspec)
          Reference Timestamp:  0.000000000
          Originator Timestamp: 0.000000000
          Receive Timestamp:    0.000000000
          Transmit Timestamp:   2844281102.736115988 (1990-02-17T22:05:02Z)
            Originator - Receive Timestamp:  0.000000000
            Originator - Transmit Timestamp: 2844281102.736115988 (1990-02-17T22:05:02Z)
```

Vemos como captura trafico, esta sincronizando su reloj NTP con cloudflare

En paralelo utiliza Wireshark o Tshark.

Abrimos wireshark y filtramos en la barra ip.addr == 192.168.144



Vamos a hacer ping a esa maquina para generar mas trafico y ver que funciona

ip.addr == 192.168.1.144

No.	Time	Source	Destination	Protocol	Length	Info
40329	107.361637959	212.227.232.46	192.168.1.144	NTP	90	NTP Version 4, server
66706	168.668176686	212.227.145.233	192.168.1.144	NTP	90	NTP Version 4, server
67135	169.333094837	217.160.163.33	192.168.1.144	NTP	90	NTP Version 4, server
67578	170.043124121	162.159.200.1	192.168.1.144	NTP	90	NTP Version 4, server
107571	237.620204570	212.227.232.46	192.168.1.144	NTP	90	NTP Version 4, server
134489	286.800909751	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=1/256, ttl=64 (reply in 134490)
135202	287.813907362	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=2/512, ttl=64 (reply in 135203)
135864	288.837923504	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=3/768, ttl=64 (reply in 135865)
136558	289.861736324	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=4/1024, ttl=64 (reply in 136559)
137225	290.885494848	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=5/1280, ttl=64 (reply in 137226)
137793	291.909500647	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=6/1536, ttl=64 (reply in 137794)
138353	292.933740529	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=7/1792, ttl=64 (reply in 138354)
138904	293.957884926	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=8/2048, ttl=64 (reply in 138905)
140007	294.981514941	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=9/2304, ttl=64 (reply in 140008)
140502	296.006031296	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=10/2560, ttl=64 (reply in 140506)
141142	297.030353591	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=11/2816, ttl=64 (reply in 141143)
141414	297.434391350	212.227.145.233	192.168.1.144	NTP	90	NTP Version 4, server
141849	298.053690192	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=12/3072, ttl=64 (reply in 141850)
142709	299.077944074	192.168.1.145	192.168.1.144	ICMP	98	Echo (ping) request id=0x0001, seq=13/3328, ttl=64 (reply in 142710)
142944	299.691110608	217.160.163.33	192.168.1.144	NTP	90	NTP Version 4, server

¿En qué capa del modelo OSI actúa principalmente?

Afecta a la Capa 3 (Red) y a la Capa 4 (Transporte)

OpenSSH

Evidencia del estado del servicio

Sudo systemctl start sshd (Inicia el servicio ssh)

Sudo systemctl status sshd (Muestra el estado del servicio ssh)

```
cmalma@localhost:~$ sudo systemctl start sshd
cmalma@localhost:~$ sudo systemctl status sshd
● sshd.service - OpenSSH server daemon
     Loaded: loaded (/usr/lib/systemd/system/sshd.service; enabled; preset: enabled)
     Active: active (running) since Tue 2026-03-03 17:39:32 CET; 35min ago
 Invocation: 6eff4c7528e940c792109e075dbf1be5
       Docs: man:sshd(8)
             man:sshd_config(5)
   Main PID: 1283 (sshd)
      Tasks: 1 (limit: 14399)
     Memory: 2M (peak: 2.3M)
        CPU: 11ms
     CGroup: /system.slice/sshd.service
             └─1283 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

mar 03 17:39:32 localhost.localdomain systemd[1]: Starting sshd.service - OpenSSH server daemon...
mar 03 17:39:32 localhost.localdomain sshd[1283]: Server listening on 0.0.0.0 port 22.
mar 03 17:39:32 localhost.localdomain sshd[1283]: Server listening on :: port 22.
mar 03 17:39:32 localhost.localdomain systemd[1]: Started sshd.service - OpenSSH server daemon.
```

Ss -tulnp | (grep 22) (Herramienta y parámetros, lista puertos abiertos(TCP/UDP), en escucha, con proceso asociado y el filtro para solo mostrar el puerto 22)

```
cmalma@localhost:~$ ss -tulnp | grep 22
tcp   LISTEN 0      128                                0.0.0.0:22        0.0.0.0:*
tcp   LISTEN 0      128                                   [::]:22           [::]:*
```

Evidencia de conexión por ssh

Ssh usuario@ip (Inicia conexión SSH al host remoto)

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ ssh cmalma@192.168.1.144
The authenticity of host '192.168.1.144 (192.168.1.144)' can't be established.
ED25519 key fingerprint is: SHA256:lwta0hin/l7dvDaSU4UYFCwNY6/zSKHSqhmVItt5j6U
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.144' (ED25519) to the list of known hosts.
cmalma@192.168.1.144's password:
Web console: https://localhost:9090/ or https://192.168.1.144:9090/

Last login: Tue Mar  3 17:40:48 2026
cmalma@localhost:~$
```

¿En qué capa del modelo OSI está actuando kali?

Es la capa 7 (es un protocolo de aplicación)

Configurar chroot SFTP en OpenSSH

Creamos usuario y su directorio personal

```
sudo useradd -m backupuser
```

Asignamos la contraseña, es necesario para restringir acceso SFTP solo a este usuario

```
sudo passwd backupuser
```

```
cmalma@localhost:~$ sudo useradd -m backupuser
cmalma@localhost:~$ sudo passwd backupuser
Nueva contraseña:
```

```
cmalma@localhost:~$ sudo passwd backupuser
Nueva contraseña:
CONTRASEÑA INCORRECTA: La contraseña no supera la verificación de diccionario - está basada en una palabra del diccionario
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
```

Evidencia del archivo de configuración modificado.

```
cmalma@localhost:~$ sudo nano /etc/ssh/sshd_config
```

```
# override default of no subsystems
Subsystem       sftp    /usr/libexec/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#       X11Forwarding no
#       AllowTcpForwarding no
#       PermitTTY no
#       ForceCommand cvs server
Subsystem sftp internal-sftp

Match User backupuser
    ChrootDirectory /home/backupuser
    ForceCommand internal-sftp
    AllowTcpForwarding no
```

Cada sentencia tiene su significado (Empieza en el segundo Subsystem):

Subsystem sftp internal-sftp → usa el SFTP interno de OpenSSH.

Match User backupuser → aplica reglas solo a ese usuario.

ChrootDirectory → encierra al usuario en su directorio.

ForceCommand internal-sftp → impide shell, solo SFTP.

AllowTcpForwarding no → desactiva túneles SSH.

Comentamos el otro subsystem sftp que hay arriba para que no haya conflicto

```
#Subsystem       sftp    /usr/libexec/openssh/sftp-server
```

Y reiniciamos la aplicación ssh.

```
cmalma@localhost:~$ sudo systemctl restart sshd
[sudo] contraseña para cmalma:
```

Comando/comandos utilizados para la creación/asignación de permisos del directorio y justificación de la sentencia/s.

Verificamos que el usuario esta correcto

```
cmalma@localhost:~$ cat /etc/passwd | grep backup
backupuser:x:1001:1001::/home/backupuser:/bin/bash
cmalma@localhost:~$
```

Crea el directorio principal para el usuario backupuser.

sudo chown root:root /home/backupuser

chown → cambia propietario.

root:root → usuario root y grupo root.

/home/backupuser → directorio afectado.

sudo chmod 755 /home/backupuser

chmod → cambia permisos.

755 → rwxr-xr-x.

-root puede leer, escribir y ejecutar.

-otros solo leer y ejecutar.

```
cmalma@localhost:~$ sudo chown root:root /home/backupuser
cmalma@localhost:~$ sudo chmod 755 /home/backupuser
cmalma@localhost:~$
```

Asigna propiedad root:root al directorio base.

sudo mkdir /home/backupuser/Upload

Crea el directorio donde sí podrá subir archivos.

sudo mkdir /home/backupuser

mkdir → crea un directorio.

/home/backupuser → será el directorio base del usuario.

sudo → permisos de administrador.

sudo chmod 700 /home/backupuser/Upload

- *700 → solo el propietario puede leer, escribir y ejecutar.*

Sirve para que solo backupuser pueda usar ese directorio.

```
cmalma@localhost:~$ sudo mkdir /home/backupuser/Upload
cmalma@localhost:~$ sudo chown backupuser:backupuser /home/backupuser/Upload
cmalma@localhost:~$ sudo chmod 700 /home/backupuser/Upload
cmalma@localhost:~$
```

Reiniciamos sshd

```
cmalma@localhost:~$ systemctl restart sshd
cmalma@localhost:~$ systemctl status sshd
● sshd.service - OpenSSH server daemon
     Loaded: loaded (/usr/lib/systemd/system/sshd.service; enabled; preset: enabled)
     Active: active (running) since Tue 2026-03-03 18:51:35 CET; 2s ago
 Invocation: 22a5824bf2df42838242b0442a8223aa
       Docs: man:sshd(8)
             man:sshd_config(5)
   Main PID: 4623 (sshd)
      Tasks: 1 (limit: 14399)
     Memory: 1.3M (peak: 1.5M)
        CPU: 8ms
     CGroup: /system.slice/sshd.service
             └─4623 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

mar 03 18:51:35 localhost.localdomain systemd[1]: Starting sshd.service - OpenSSH server daemon...
mar 03 18:51:35 localhost.localdomain sshd[4623]: Server listening on 0.0.0.0 port 22.
mar 03 18:51:35 localhost.localdomain sshd[4623]: Server listening on :: port 22.
mar 03 18:51:35 localhost.localdomain systemd[1]: Started sshd.service - OpenSSH server daemon.
```

Verificamos la defensa del sftp:

Entramos en el servidor con sftp y no con ssh porque el usuario tiene forzado el internal-sftp

sftp backupuser@IP_ALMA

```
cmalma@localhost:~$ sftp backupuser@192.168.1.144
The authenticity of host '192.168.1.144 (192.168.1.144)' can't be established.
ED25519 key fingerprint is SHA256:lwta0hin/l7dvDaSU4UYFCwNY6/zSKHSqhmVItt5j6U.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.144' (ED25519) to the list of known hosts.
backupuser@192.168.1.144's password:
Connected to 192.168.1.144.
sftp>
```

Creamos un archivo.txt y lo intentamos descargar en la carpeta creada upload

```
cmalma@localhost:~$ echo "prueba" > archivo.txt
cmalma@localhost:~$ sftp backupuser@192.168.1.144
backupuser@192.168.1.144's password:
Connected to 192.168.1.144.
sftp> ls
Upload
```

```
sftp> cd Upload/
realpath /Upload/Upload/: No such file
sftp> put archivo.txt
Uploading archivo.txt to /Upload/archivo.txt
archivo.txt
sftp> ls
archivo.txt
sftp>
```

Comprobamos que no pueda salir o realizar acciones que hemos restringido.

1. Intentar salir del chroot

```
sftp> ls
Upload
sftp> cd ..
sftp> ls
Upload
sftp>
```

2. Intentar escribir en el directorio raíz

```
sftp> ls
Upload
sftp> put archivo.txt
Uploading archivo.txt to /archivo.txt
dest open "/archivo.txt": Permission denied
```

3. Intentar crear un directorio en raíz

```
sftp> mkdir prueba
remote mkdir "/prueba": Permission denied
sftp>
```

4. Intentar ejecutar comandos de Shell

```
sftp> ls -la
drwxr-xr-x    ? root     root           92 Mar  3 18:49 .
drwxr-xr-x    ? root     root           92 Mar  3 18:49 ..
-rw-r--r--    ? 1001     1001           18 Oct 29  2024 .bash_logout
-rw-r--r--    ? 1001     1001          144 Oct 29  2024 .bash_profile
-rw-r--r--    ? 1001     1001          522 Oct 29  2024 .bashrc
drwxr-xr-x    ? 1001     1001           39 Mar  2 17:31 .mozilla
drwx------    ? 1001     1001           25 Mar  3 18:59 Upload
sftp> !
cmalma@localhost:~$
```

Te echa directamente cuando quieres ejecutar comandos o abrirte una Shell, al listar los permisos puedes ver que no tienes los permisos para salir tampoco de ejecutar

5. Intentar acceder por SSH normal

```
cmalma@localhost:~$ ssh backupuser@192.168.1.144
backupuser@192.168.1.144's password:
This service allows sftp connections only.
Connection to 192.168.1.144 closed.
cmalma@localhost:~$
```

6. Intentar túnel (Lo bloqueamos con AllowTcpFowarding).

```
cmalma@localhost:~$ ssh -L 8080:localhost:80 backupuser@192.168.1.144
backupuser@192.168.1.144's password:
This service allows sftp connections only.
Connection to 192.168.1.144 closed.
cmalma@localhost:~$ sftp -L 8080:localhost:80 backupuser@192.168.1.144
unknown option -- L
usage: sftp [-46AaCfNpqrv] [-B buffer_size] [-b batchfile] [-c cipher]
          [-D sftp_server_command] [-F ssh_config] [-i identity_file]
          [-J destination] [-l limit] [-o ssh_option] [-P port]
          [-R num_requests] [-S program] [-s subsystem | sftp_server]
          [-X sftp_option] destination
cmalma@localhost:~$
```

aunque sftp no suele permitir túneles igualmente.

¿En qué capa del modelo OSI está actuando Alma?

Esta actuando en la capa 7

Listas de control de acceso y firewall (ACL)

Crear carpeta y asignar permisos

Crear directorio

sudo mkdir -p /var/log/backup

```
cmalma@localhost:~$ sudo mkdir -p /var/log/backup
[sudo] contraseña para cmalma:
cmalma@localhost:~$
```

Qué hace:

- *mkdir* crea directorio.
- *-p* crea también directorios intermedios si no existen.

Sirve para crear la carpeta donde se almacenarán los logs de backup.

Cambiar propietario y grupo

sudo chown root:backupuser /var/log/backup

```
cmalma@localhost:~$ sudo chown root:backupuser /var/log/backup
[sudo] contraseña para cmalma:
cmalma@localhost:~$
```

Qué hace:

- *chown* → cambia propietario.
- *root* → propietario del directorio.
- *backupuser* → grupo asociado.

Permite que el grupo backupuser tenga acceso controlado.

Asignar permisos

sudo chmod 770 /var/log/backup

```
cmalma@localhost:~$ sudo chmod 770 /var/log/backup
cmalma@localhost:~$
```

Qué hace:

- *chmod* → cambia permisos.
- *770* →
    - root: rwx
    - grupo: rwx
    - otros: sin acceso

Sirve para restringir acceso solo al administrador y al grupo.

Evidencia

ls -ld /var/log/backup

Ejemplo esperado:

drwxrwx--- root backupuser /var/log/backup

```
cmalma@localhost:~$ ls -ld /var/log/backup
drwxrwx---. 2 root backupuser 6 mar  5 16:37 /var/log/backup
cmalma@localhost:~$
```

Explicación de getfacl / setfacl

getfacl

Sirve para ver las listas de control de acceso (ACL) de un archivo o directorio.

Permite comprobar permisos avanzados más allá de los permisos tradicionales de Linux.

setfacl

Sirve para modificar o asignar permisos ACL a usuarios o grupos específicos.

Permite dar permisos adicionales sin cambiar propietario o grupo.

Comprobar ACL actuales

getfacl /var/log/backup

```
cmalma@localhost:~$ getfacl /var/log/backup
getfacl: Eliminando '/' inicial en nombres de ruta absolutos
# file: var/log/backup
# owner: root
# group: backupuser
user::rwx
group::rwx
other::---
```

Esto mostrará las ACL configuradas actualmente.

Dar permisos a backupuser

Asignar permisos de lectura, escritura y ejecución:

sudo setfacl -m u:backupuser:rwx /var/log/backup

```
cmalma@localhost:~$ sudo setfacl -R -m u:backupuser:rwx /var/log/backup
[sudo] contraseña para cmalma:
cmalma@localhost:~$
```

Explicación:

- *setfacl* modifica ACL.
- *-m* modificar entrada.
- *u:backupuser* usuario al que se aplican permisos.
- *rwx* permisos de lectura, escritura y ejecución.

Esto añade permisos ACL al usuario backupuser.

Comprobar

getfacl /var/log/backup

Ahora debería aparecer algo como:

user:backupuser:rwx

```
cmalma@localhost:~$ sudo setfacl -m u:backupuser:rwx /var/log/backup
cmalma@localhost:~$ getfacl /var/log/backup
getfacl: Eliminando '/' inicial en nombres de ruta absolutos
# file: var/log/backup
# owner: root
# group: backupuser
user::rwx
user:backupuser:rwx
group::rwx
mask::rwx
other::---
```

Herencia de ACL

Queremos que todo lo que se cree dentro herede los permisos.

Aplicar ACL recursivamente

sudo setfacl -R -m u:backupuser:rwx /var/log/backup

```
cmalma@localhost:~$ sudo setfacl -R -m u:backupuser:rwx /var/log/backup
cmalma@localhost:~$
```

Explicación:

- *-R* → aplica recursivamente a todo el contenido.
- *-m* → modifica ACL.

Establecer ACL por defecto

sudo setfacl -d -m u:backupuser:rwx /var/log/backup

```
cmalma@localhost:~$ sudo setfacl -d -m u:backupuser:rwx /var/log/backup
çcmalma@localhost:~$
```

Explicación:

- -d → define ACL por defecto.
- Esto hace que **todo archivo nuevo herede esos permisos**.

Comprobar ACL finales

```
cmalma@localhost:~$ getfacl /var/log/backup
getfacl: Eliminando '/' inicial en nombres de ruta absolutos
# file: var/log/backup
# owner: root
# group: backupuser
user::rwx
user:backupuser:rwx
group::rwx
mask::rwx
other::---
default:user::rwx
default:user:backupuser:rwx
default:group::rwx
default:mask::rwx
default:other::---
```

getfacl /var/log/backup

Verás algo como:

default:user:backupuser:rwx

Evidencia final

Comando:

getfacl /var/log/backup

```
cmalma@localhost:~$ getfacl /var/log/backup
getfacl: Eliminando '/' inicial en nombres de ruta absolutos
# file: var/log/backup
# owner: root
# group: backupuser
user::rwx
user:backupuser:rwx
group::rwx
mask::rwx
other::---
default:user::rwx
default:user:backupuser:rwx
default:group::rwx
default:mask::rwx
default:other::---
```

Debe mostrar ACL normales y ACL por defecto.

Iptables en AlmaLinux

Comprobar iptables-services

Comprobar si está instalado

rpm -q iptables-services

- *rpm -q* consulta si un paquete está instalado.
- *iptables-services* paquete que permite gestionar iptables como servicio.

Instalar si no está

sudo dnf install iptables-services -y

```
cmalma@localhost:~$ sudo dnf install iptables-services -y
[sudo] contraseña para cmalma:
Última comprobación de caducidad de metadatos hecha hace 0:38:45, el jue 05 mar 2026 16:37:16.
Dependencias resueltas.
==========================================================================================================
 Paquete                          Arquitectura        Versión                       Repositorio          Tam.
==========================================================================================================
Instalando:
 iptables-nft-services            noarch              1.8.11-12.el10_1              appstream            19 k

Resumen de la transacción
==========================================================================================================
Instalar  1 Paquete

Tamaño total de la descarga: 19 k
Tamaño instalado: 30 k
Descargando paquetes:
iptables-nft-services-1.8.11-12.el10_1.noarch.rpm                                375 kB/s |  19 kB     00:00
----------------------------------------------------------------------------------------------------------
Total                                                                             46 kB/s |  19 kB     00:00
Ejecutando verificación de operación
Verificación de operación exitosa.
Ejecutando prueba de operaciones
Prueba de operación exitosa.
Ejecutando operación
  Preparando          :                                                                                  1/1
  Instalando          : iptables-nft-services-1.8.11-12.el10_1.noarch                                    1/1
  Ejecutando scriptlet: iptables-nft-services-1.8.11-12.el10_1.noarch                                    1/1

Instalado:
  iptables-nft-services-1.8.11-12.el10_1.noarch

¡Listo!
cmalma@localhost:~$
```

- *dnf install* instala paquete.
- *-y* acepta automáticamente.

Detener firewall de Alma

Alma usa normalmente **firewalld**.

sudo systemctl stop firewalld

Detiene el firewall.

sudo systemctl disable firewalld

```
cmalma@localhost:~$ sudo systemctl stop firewalld
cmalma@localhost:~$ sudo systemctl disable firewalld
Removed '/etc/systemd/system/multi-user.target.wants/firewalld.service'.
Removed '/etc/systemd/system/dbus-org.fedoraproject.FirewallD1.service'.
cmalma@localhost:~$
```

Evita que arranque al iniciar el sistema.

Limpiar reglas de iptables

sudo iptables -F

- *-F* flush (borra reglas existentes).

```
cmalma@localhost:~$ sudo iptables -F
cmalma@localhost:~$
```

sudo iptables -X

- *-X* → elimina cadenas personalizadas.

```
cmalma@localhost:~$ sudo iptables -X
cmalma@localhost:~$
```

Sirve para evitar conflictos con reglas anteriores.

Crear regla SSH

Antes de activar el modo restrictivo debemos permitir SSH.

sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT

```
cmalma@localhost:~$ sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
cmalma@localhost:~$
```

Explicación:

- *-A INPUT* añade regla a la cadena de entrada.
- *-p tcp* protocolo TCP.
- *--dport 22* puerto SSH.
- *-j ACCEPT* → permite tráfico.

Evita bloquear el acceso SSH al activar DROP.

Configurar iptables modo restrictivo

Primero permitir tráfico básico.

Permitir tráfico local

sudo iptables -A INPUT -i lo -j ACCEPT

- *-i lo → interfaz loopback.*

```
cmalma@localhost:~$ sudo iptables -A INPUT -i lo -j ACCEPT
cmalma@localhost:~$
```

Permitir conexiones establecidas

sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

- *-m state* módulo de estado.
- *ESTABLISHED,RELATED* conexiones ya abiertas o relacionadas.

```
cmalma@localhost:~$ sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
cmalma@localhost:~$
```

Política restrictiva

sudo iptables -P INPUT DROP

- *-P* policy.
- *INPUT DROP* bloquea todo lo que no esté permitido.

```
cmalma@localhost:~$ sudo iptables -P INPUT DROP
cmalma@localhost:~$
```

Guardar reglas

sudo service iptables sabe

```
cmalma@localhost:~$ sudo service iptables save
iptables: Saving firewall rules to /etc/sysconfig/iptables: [  OK  ]
```

Guarda las reglas en:

/etc/sysconfig/iptables

```
root@localhost:/home/cmalma# cat /etc/sysconfig/iptables
# Generated by iptables-save v1.8.11 (nf_tables) on Thu Mar  5 17:20:55 2026
*filter
:INPUT DROP [0:0]
:FORWARD ACCEPT [0:0]
:OUTPUT ACCEPT [0:0]
-A INPUT -p tcp -m tcp --dport 22 -j ACCEPT
-A INPUT -i lo -j ACCEPT
-A INPUT -m state --state RELATED,ESTABLISHED -j ACCEPT
COMMIT
# Completed on Thu Mar  5 17:20:55 2026
```

Activar persistencia

sudo systemctl enable iptables

```
root@localhost:/home/cmalma# sudo systemctl enable iptables
Created symlink '/etc/systemd/system/multi-user.target.wants/iptables.service' → '/usr/lib/systemd/system/iptables.se
rvice'.
```

sudo systemctl start iptables

```
root@localhost:/home/cmalma# sudo systemctl start iptables
root@localhost:/home/cmalma#
```

Hace que iptables se cargue al iniciar el sistema.

Verificar iptables

Mostrar reglas

sudo iptables -L -n -v

```
root@localhost:/home/cmalma# sudo iptables -L -n -v
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     tcp  --  *      *       0.0.0.0/0            0.0.0.0/0            tcp dpt:22
    0     0 ACCEPT     all  --  lo     *       0.0.0.0/0            0.0.0.0/0
    3   228 ACCEPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0            state RELATED,ESTABLISHED

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 3 packets, 228 bytes)
 pkts bytes target     prot opt in     out     source               destination
root@localhost:/home/cmalma#
```

Explicación:

- -L → lista reglas.
- -n → no resuelve nombres.
- -v → modo detallado.

Guardar reglas en archivo

sudo iptables -L -n -v > /tmp/reglas.txt

- > → redirige salida a archivo.

```
root@localhost:/home/cmalma# sudo iptables -L -n -v > /tmp/reglas.txt
root@localhost:/home/cmalma#
```

Probar conexión desde Kali

Desde Kali:

ssh usuario@IP_ALMA

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ ssh cmalma@192.168.1.144
cmalma@192.168.1.144's password:
Web console: https://localhost:9090/

Last login: Thu Mar  5 16:09:58 2026
cmalma@localhost:~$
```

Debe permitir conexión porque el puerto 22 está abierto.

Pregunta del ejercicio

¿En qué capa OSI actúa Alma?

Capa 3 y 4

Porque iptables filtra tráfico basándose en:

IP → capa 3 (red)

TCP/UDP puertos → capa 4 (transporte)

Alma está actuando principalmente en las capas 3 (Red) y 4 (Transporte) del modelo OSI, ya que iptables filtra tráfico basándose en direcciones IP y puertos TCP/UDP.

¿Qué otras medidas nos ofrecen iptables para securizar las conexiones?

Limitar intentos SSH (anti brute force)

```
root@localhost:/home/cmalma# sudo iptables -A INPUT -p tcp --dport 22 -m limit --limit 3/minute -j ACCEPT
root@localhost:/home/cmalma#
```

sudo iptables -A INPUT -p tcp --dport 22 -m limit --limit 3/minute -j ACCEPT

Permite máximo 3 conexiones por minuto.

Bloquear una IP específica

```
root@localhost:/home/cmalma# sudo iptables -A INPUT -s 192.168.1.50 -j DROP
root@localhost:/home/cmalma#
```

sudo iptables -A INPUT -s 192.168.1.50 -j DROP

Bloquea tráfico de una IP concreta.

Permitir acceso solo una red

Permitir solo una IP concreta:

sudo iptables -A INPUT -p tcp -s 192.168.1.50 --dport 22 -j ACCEPT

```
root@localhost:/home/cmalma# sudo iptables -A INPUT -p tcp -s 192.168.1.50 --dport 22 -j ACCEPT
root@localhost:/home/cmalma#
```

Ahora solo esa máquina puede usar SSH.

Mitigación de ICMP

Comprobar política INPUT DROP

Primero hay que verificar si la política de entrada está en modo restrictivo.

sudo iptables -L

```
root@localhost:/home/cmalma# sudo iptables -L
Chain INPUT (policy DROP)
target     prot opt source               destination
ACCEPT     tcp  --  anywhere             anywhere             tcp dpt:ssh
ACCEPT     all  --  anywhere             anywhere
ACCEPT     all  --  anywhere             anywhere             state RELATED,ESTABLISHED
ACCEPT     tcp  --  anywhere             anywhere             tcp dpt:ssh limit: avg 3/min burst 5
DROP       all  --  192.168.1.50         anywhere
ACCEPT     tcp  --  192.168.1.0/24       anywhere             tcp dpt:ssh

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
root@localhost:/home/cmalma#
```

O:

sudo iptables -L -n -v

```
root@localhost:/home/cmalma# sudo iptables -L -n -v
Chain INPUT (policy DROP 2186 packets, 315K bytes)
 pkts bytes target     prot opt in     out     source               destination
   51  7509 ACCEPT     tcp  --  *      *       0.0.0.0/0            0.0.0.0/0           tcp dpt:22
    0     0 ACCEPT     all  --  lo     *       0.0.0.0/0            0.0.0.0/0
  184 14331 ACCEPT     all  --  *      *       0.0.0.0/0            0.0.0.0/0           state RELATED,ESTABLISHED
    0     0 ACCEPT     tcp  --  *      *       0.0.0.0/0            0.0.0.0/0           tcp dpt:22 limit: avg 3/min burst 5
    0     0 DROP       all  --  *      *       192.168.1.50         0.0.0.0/0
    0     0 ACCEPT     tcp  --  *      *       192.168.1.0/24       0.0.0.0/0           tcp dpt:22

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 231 packets, 21587 bytes)
 pkts bytes target     prot opt in     out     source               destination
root@localhost:/home/cmalma#
```

Explicación:

- -L → lista reglas.
- -n → no resuelve nombres.
- -v → muestra información detallada.

Método 1 – Bloquear ICMP con iptables

Comando:

sudo iptables -A INPUT -p icmp -j DROP

```
root@localhost:/home/cmalma# sudo iptables -A INPUT -p icmp -j DROP
root@localhost:/home/cmalma#
```

Explicación:

- -A INPUT → añade regla a tráfico entrante.
- -p icmp → aplica a protocolo ICMP.

-j DROP → descarta paquetes.

Esto bloquea ping y otros mensajes ICMP.

Guardar reglas

sudo service iptables sabe

```
root@localhost:/home/cmalma# sudo service iptables save
iptables: Saving firewall rules to /etc/sysconfig/iptables: [  OK  ]
root@localhost:/home/cmalma#
```

Guarda la configuración para que persista.

Método 2 – Bloqueo a nivel de Kernel

Linux puede ignorar ICMP directamente desde el kernel.

Comando temporal:

sudo sysctl -w net.ipv4.icmp_echo_ignore_all=1

```
root@localhost:/home/cmalma# sudo sysctl -w net.ipv4.icmp_echo_ignore_all=1
net.ipv4.icmp_echo_ignore_all = 1
root@localhost:/home/cmalma#
```

Explicación:

- sysctl → modifica parámetros del kernel.
- icmp_echo_ignore_all=1 → ignora todos los pings.

Hacerlo persistente

Editar archivo de configuración:

sudo nano /etc/sysctl.conf

Añadir al final:

net.ipv4.icmp_echo_ignore_all = 1

Guardar y aplicar:

sudo sysctl -p

Esto hace que la configuración se cargue al iniciar el sistema.

```
  GNU nano 8.1                                        /etc/sysctl.conf
# sysctl settings are defined through files in
# /usr/lib/sysctl.d/, /run/sysctl.d/, and /etc/sysctl.d/.
#
# Vendors settings live in /usr/lib/sysctl.d/.
# To override a whole file, create a new file with the same in
# /etc/sysctl.d/ and put new settings there. To override
# only specific settings, add a file with a lexically later
# name in /etc/sysctl.d/ and put new settings there.
#
# For more information, see sysctl.conf(5) and sysctl.d(5).
sudo nano /etc/sysctl.conf
```

Evidencia

Mostrar configuración:

cat /etc/sysctl.conf

```
root@localhost:/home/cmalma# cat /etc/sysctl.conf
# sysctl settings are defined through files in
# /usr/lib/sysctl.d/, /run/sysctl.d/, and /etc/sysctl.d/.
#
# Vendors settings live in /usr/lib/sysctl.d/.
# To override a whole file, create a new file with the same in
# /etc/sysctl.d/ and put new settings there. To override
# only specific settings, add a file with a lexically later
# name in /etc/sysctl.d/ and put new settings there.
#
# For more information, see sysctl.conf(5) and sysctl.d(5).
sudo nano /etc/sysctl.conf
root@localhost:/home/cmalma#
```

O:

sysctl net.ipv4.icmp_echo_ignore_all

```
root@localhost:/home/cmalma# sysctl net.ipv4.icmp_echo_ignore_all
net.ipv4.icmp_echo_ignore_all = 1
root@localhost:/home/cmalma#
```

Verificar desde Kali

Desde Kali ejecuta:

Ping -c 4 IP_ALMA

Resultado esperado:

Destination Host Unreachable

o

Request timeout

Porque Alma ignora ICMP.

```
┌──(cm㉿HackingPocoEtico)-[~]
└─$ ping -c 4 192.168.1.144
PING 192.168.1.144 (192.168.1.144) 56(84) bytes of data.

--- 192.168.1.144 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3068ms
```

¿Qué es ICMP?

ICMP (Internet Control Message Protocol) es un protocolo utilizado para enviar **mensajes de control y diagnóstico en redes IP**.

Se usa principalmente para:

- comprobar conectividad (ping)
- notificar errores de red
- informar del estado de la red

Funciona sobre la capa 3 del modelo OSI (red).

¿Por qué es buena idea bloquearlo?

Bloquear ICMP puede mejorar la seguridad porque:

- evita descubrimiento de hosts mediante ping
- dificulta escaneos de red
- reduce información que un atacante puede obtener

Aunque en muchos entornos se permite parcialmente para diagnóstico.

Diferencias entre método 1 y método 2

Método 1 – iptables

- Filtra paquetes a nivel de firewall.
- Se aplica al tráfico que entra o sale.
- Permite reglas más detalladas.

Método 2 – kernel

- El propio sistema ignora ICMP.
- No depende del firewall.
- Es una configuración más profunda del sistema.